

CCSP TLS PKI 密碼學

CCSP flashcards for Knowt. 40 cards. Upload this PDF to AI PDF Summarizer.

Q001 用一句話說明 TLS 四段工作？

A Certificate 綁定身分與 public key ; digital signature 證明持有 private key ; (EC)DHE 建立 shared secret ; symmetric crypto 保護實際流量。

Q002 Symmetric encryption 的核心？

A 同一把 secret key 做加解密。適合大量資料，所以 bulk / TLS application traffic 用它。

Q003 Symmetric 最大問題是什麼？

A Key distribution : 雙方如何安全取得同一把 secret 。

Q004 Asymmetric cryptography 使用什麼？

A Public key + private key 這一對 mathematically related keys 。

Q005 要給 Bob 機密訊息時用哪把 key 加密？

A Bob 的 public key 加密，Bob 的 private key 解密。目的是 confidentiality 。

Q006 數位簽章用哪把 key ？

A 簽署者 private key 簽名，對應 public key 驗證。

Q007 Digital signature 提供什麼、不提供什麼？

A 提供 integrity 、 authenticity 、 non-repudiation support ；不提供 confidentiality 。

Q008 為什麼不要說「用 private key 加密」來形容簽章？

A 這是舊簡化。CCSP 較安全的說法是 sign with private key 、verify with public key 。

Q009 Hash 單獨能證明是誰產生的嗎？

A 不能。任何人改完內容都可以重算 hash 。Hash 只能協助偵測修改。

Q010 HMAC 為什麼通常不能給真正 non-repudiation ？

A 雙方共享同一 secret ，理論上都能做出 valid MAC 。

Q011 X.509 certificate 最重要的一句？

A 把 identity / subject 與 public key 綁在一起，並由 CA 數位簽章證明此 binding。

Q012 Certificate 裡有 private key 嗎？

A 不應有。公開憑證帶 public key；private key 必須另外保密。

Q013 CA 的主要工作是什麼？

A 依程序驗證 subject，並用 CA private key 簽署憑證。不是幫你加密流量。

Q014 誰驗證 CA 在憑證上的簽章？

A Client 用 CA public key 驗證。

Q015 PKI chain of trust 怎麼走？

A Root CA → Intermediate CA → server certificate。Trust store 預先信任 root。

Q016 憑證驗證至少要看哪些？

A 簽章 / 鏈、有效期、主體 / hostname (SAN)、key usage、撤銷 (CRL / OCSP)。

Q017 憑證過期後 public key 數學上會壞掉嗎？

A 不會。但 PKI 驗證應拒絕，因為超出核准有效期。這是 trust validity 不是數學失效。

Q018 只偷到 server 的公開憑證能冒充伺服器嗎？

A 不能。關鍵秘密是 private key。

Q019 TLS 是 hybrid cryptosystem 的原因？

A 非對稱 / DH 做認證與金鑰建立；對稱金鑰做大量加密。全非對稱太慢，全對稱無法安全起步。

Q020 TLS 1.3 中 certificate 與 ECDHE 各做什麼？

A Certificate / signature = authentication；ECDHE = key establishment。兩者不同功能。

Q021 TLS application traffic 用什麼加密？

A Derived symmetric traffic keys，常見 AES-GCM 或 ChaCha20-Poly1305 (AEAD)。

Q022 ECDHE 最大安全特性？

A Forward secrecy：每個 session 用 ephemeral keys，長期金鑰失竊不應讓過去流量自動可解。

Q023 ECDSA 與 ECDHE 差在哪？

A ECDSA = digital signature；ECDHE = key establishment。不要混。

Q024 TLS 1.3 還用傳統 RSA static key exchange 嗎？

A 不用。那是舊 TLS 常見、且無 forward secrecy 的做法。

Q025 為什麼「X.509 產生 shared secret」不精確？

A 憑證主要做身分綁定與認證；TLS 1.3 的 shared secret 通常由 (EC)DHE 建立。

Q026 AES-GCM 為什麼常出現在 TLS？

A 它是 AEAD，可同時提供機密性與密文完整性。

Q027 TLS 1.3 cipher suite 名稱還會寫出 ECDHE / RSA 嗎？

A 通常不會。TLS 1.3 把憑證演算法與 ECDHE group 分開協商，例如 TLS_AES_128_GCM_SHA256。

Q028 mTLS 是什麼？

A 雙方都出示憑證：server authentication + client certificate authentication。一般公開 HTTPS 未必做 client cert。

Q029 CRL 與 OCSP 差在哪？

A CRL 下載撤銷清單；OCSP 詢問特定憑證的撤銷狀態。

Q030 Root CA 為什麼能被信任？

A 它是 trust anchor，已預先放在 OS / browser trust store。不是因為 self-signed 就自動可信。

Q031 Self-signed certificate 的信任問題？

A Subject = Issuer，密碼學上可驗簽，但缺少外部可信 CA 時必須另有 out-of-band trust。

Q032 Certificate、KMS、HSM 差在哪？

A Certificate = 身分與 public key 綁定；KMS = 金鑰生命週期管理；HSM = 受保護硬體做金鑰運算。

Q033 大量資料加密看到題目先選什麼？

A Symmetric。

Q034 問「誰簽的、完整性 + 不可否認」選什麼？

A Digital signature。

Q035 問「完整性 + 共享密鑰認證」選什麼？

A HMAC。

Q036 問 TLS fresh shared secret 選什麼？

A (EC)DHE。

Q037 問 forward secrecy 選什麼？

A Ephemeral Diffie–Hellman / ECDHE。

Q038 最不能外洩的是什麼？

A Private key。

Q039 Authentication 與 confidentiality 各回答什麼？

A Authentication：你是誰？Confidentiality：未授權者能否讀懂？

Q040 瀏覽器收到 server X.509 的主要密碼學目的？

A 透過可信 CA 簽章，把伺服器身分綁定到 public key。